

Security+ 2.3 · Cross-Site Scripting (XSS)

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.3 — Cross-Site Scripting (XSS)**
(8:34) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Injeta JavaScript num site de terceiros que roda COM AS CREDENCIAIS DA VÍTIMA (cookie, sessão). 3 tipos: Refletido (no link — vítima clica), Persistido (fica no DB — afeta todos que ver), DOM-based. Defesa: sanitize/escape output, HttpOnly cookie, CSP (Content Security Policy).

Highlights que a prova cobra

- XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA
- Persistido = armazenado no banco; refletido = vem do query string
- HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing

Dicas de prova & Cenários Típicos

- 'malicious JavaScript runs in the victim's browser' = XSS
- 'Content Security Policy as defense' = XSS mitigation

Cenário clássico de exame: Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.3 — Cross-Site Scripting (XSS))

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **WAF:** Web Application Firewall: Dispositivo ou serviço de segurança que inspeciona o tráfego HTTP/HTTPS na camada de aplicação (Camada 7), filtrando e bloqueando ataques web comuns como SQL Injection, Cross-Site Scripting (XSS) e CSRF.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários:

- A) XSS (Cross-Site Scripting)
- B) CSRF
- C) SQLi
- D) Buffer overflow

2. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A) Firewall stateful tradicional
- B) Web Application Firewall (WAF)
- C) Switch Layer 2
- D) Hub

3. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...

4. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'malicious JavaScript runs in the victim's browser' = XSS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'malicious JavaScript runs in the victim's browser' = XSS...

7. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Content Security Policy as defense' = XSS mitigation'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'Content Security Policy as defense' = XSS mitigation...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum executa script em quem vê o coment...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — XSS (Cross-Site Scripting).

✓ **Por que está certa:** XSS (Cross-Site Scripting) é a vulnerabilidade que permite a injeção de scripts maliciosos (geralmente JavaScript) em páginas web visualizadas por outros usuários. No XSS, o atacante explora a falta de sanitização de entrada e/ou codificação de saída para que o navegador da vítima execute o código no contexto da aplicação vulnerável. Existem três tipos principais: armazenado (persistente), refletido (não persistente) e baseado em DOM. O impacto inclui roubo de cookies de sessão, sequestro de sessão, redirecionamento malicioso, keylogging e desfiguração de páginas. A questão descreve exatamente esse cenário: 'Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários', o que é a definição precisa de XSS conforme o objetivo SY0-701 1.3 (vulnerabilidades de aplicação) e 2.2 (ameaças baseadas em aplicações).

✗ Por que as outras estão erradas:

- **CSRF:** CSRF (Cross-Site Request Forgery) é um ataque que força o navegador da vítima, já autenticada em um site, a executar ações não intencionais nesse site (ex.: transferência bancária, alteração de senha). O atacante não injeta script na página; ele engana a vítima para que seu navegador envie uma requisição forjada, aproveitando a confiança que o site tem no cookie de sessão da vítima. Portanto, CSRF não executa código no navegador de outros usuários; ele explora a confiança da aplicação no navegador da vítima. A questão pede explicitamente injeção de script que roda no navegador de outros usuários, o que não é o mecanismo do CSRF.
- **SQLi:** SQL Injection (SQLi) é uma técnica de injeção de comandos SQL maliciosos em entradas de aplicação para manipular o banco de dados subjacente. O atacante pode extrair, modificar ou deletar dados, contornar autenticação, executar comandos no sistema operacional, entre outros. O alvo é o servidor de banco de dados, não o navegador de outros usuários. O SQLi não injeta scripts que rodam no navegador da vítima; ele explora a camada de persistência. A descrição do enunciado fala em 'rodar no navegador de OUTROS usuários', o que é característico de XSS, não de SQLi.
- **Buffer overflow:** Buffer overflow (estouro de buffer) é uma vulnerabilidade de corrupção de memória em que um programa escreve mais dados do que o buffer alocado pode conter, sobrescrevendo áreas adjacentes da memória. Isso pode levar à execução de código arbitrário, travamento do sistema ou escalção de privilégios. O ataque ocorre no processo do software vulnerável, não no navegador de outros usuários. Embora navegadores possam sofrer buffer overflow, o cenário descrito é de injeção de script em página web para execução no navegador de terceiros, o que é domínio específico de XSS. Buffer overflow não é uma técnica de injeção de script em páginas web.

2) B — Web Application Firewall (WAF).

✓ **Por que está certa:** O **Web Application Firewall (WAF)** é um dispositivo de segurança que opera na camada de aplicação (Layer 7 do modelo OSI) e é projetado para inspecionar o tráfego HTTP/HTTPS, protegendo aplicações web contra ataques como SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), entre outros. Ele analisa o conteúdo das requisições e respostas, aplicando regras baseadas em assinaturas ou comportamento anômalo. No syllabus da CompTIA Security+ (SY0-701), o WAF é explicitamente citado como um controle de segurança de camada de aplicação para proteger servidores web. Portanto, é a resposta exata para a descrição.

✗ Por que as outras estão erradas:

- **Firewall stateful tradicional:** Um firewall stateful tradicional opera nas camadas de rede e transporte (Layer 3 e 4). Ele mantém uma tabela de estado das conexões e permite ou bloqueia

pacotes com base em endereços IP, portas e estado da conexão. No entanto, ele não inspeciona o conteúdo da camada de aplicação (HTTP/HTTPS) e, portanto, não consegue detectar ataques como SQL injection ou XSS. Para inspecionar conteúdo HTTP/HTTPS, seria necessário um firewall de próxima geração (NGFW) com inspeção profunda de pacotes ou um WAF. Logo, o firewall stateful tradicional não atende ao requisito de operar na camada de aplicação e inspecionar conteúdo.

- *Switch Layer 2*: Um switch Layer 2 opera na camada de enlace de dados (Layer 2) e é responsável por encaminhar quadros Ethernet com base em endereços MAC. Ele não possui funcionalidades de inspeção de tráfego em nível de aplicação, muito menos de conteúdo HTTP/HTTPS. Sua função é conectar dispositivos dentro de uma mesma rede local, segmentando domínios de colisão. Não é um dispositivo de segurança de camada 7 e não pode inspecionar conteúdo. Portanto, está incorreto.

- *Hub*: Um hub é um dispositivo de camada física (Layer 1) que simplesmente repete sinais elétricos para todas as portas, sem qualquer inteligência de encaminhamento ou inspeção. Ele não opera em camadas superiores e não oferece nenhuma funcionalidade de segurança, muito menos inspeção de conteúdo HTTP/HTTPS. Hubs são obsoletos e substituídos por switches. Logo, não se aplica ao contexto de segurança de camada de aplicação.

3) D — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'malicious JavaScript runs in the victim's browser' = XSS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'malicious JavaScript runs in the victim's browser' = XSS.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'Content Security Policy as defense' = XSS mitigation....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'Content Security Policy as defense' = XSS mitigation.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum executa script em quem vê o coment....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

